

ENTERPRISE ARCHITECTURE

Advisor Portfolio Rebalancing & Suitability Review Platform

High-Level Design (HLD)

Architecture Design Document

Document Version	1.0
Date	10 June 2025
Status	Draft
Classification	Confidential
Prepared By	Generated by Design Document Generator
Reviewed By	Enterprise Architecture Review Board

Document Control

This document provides the authoritative architecture design specification for the project. It is intended for consumption by architects, technical leads, and senior developers.

Version History

Version	Date	Author	Description
1.0	10 June 2025	Generated by Design Document Generator	Initial release

Table of Contents

Note: Update this table of contents after opening the document in Microsoft Word (References → Update Table).

- 1. Executive Summary
 - 1.1 In Scope
 - 1.2 Out of Scope
- 2. Assumptions & Constraints
- 3. High-Level Design (HLD)
 - 3.1 System Architecture Overview
 - 3.2 Architecture Principles
 - 3.3 Major Components & Modules
 - 3.4 User & Data Flow
 - 3.5 External Integrations
 - 3.6 Architecture Diagram
 - 3.7 Component Interaction Diagram
 - 3.8 Data Flow Diagram

1. Executive Summary

This Architecture Design Document defines the technical blueprint for the Advisor Portfolio Rebalancing & Suitability Review Platform. The platform aims to digitize and automate the end-to-end rebalancing lifecycle for wealth advisors, addressing inefficiencies, compliance risks, and audit deficiencies inherent in current manual processes. The solution will provide a unified web-based interface for advisors and compliance officers, embedding suitability validation, multi-stage approval workflows, and immutable audit trails. Key architectural decisions include a cloud-native, multi-tier architecture leveraging microservices, secure SSO integration, and a configurable rules engine for compliance. The platform will support AI-assisted client summary generation, robust RBAC/MFA security, and full auditability. Expected business outcomes are a 30–40% improvement in advisor productivity, 40–50% reduction in compliance effort, and full regulatory alignment through centralized, tamper-proof records. The design ensures scalability to 500 concurrent users, high availability, and extensibility for future integrations (e.g., CRM, live market data). Security and compliance are prioritized through encryption, access controls, and adherence to OWASP and industry standards.

1.1 In Scope

- Advisor dashboard with drift indicators and proposal status
- Portfolio detail view with holdings, risk profile, and proposal history
- Rebalancing proposal creation, editing, versioning, and submission
- Automated suitability validation engine with configurable rules
- Multi-stage approval workflow (Draft → Compliance Review → Approved/Rejected)
- Immutable audit trail and reporting with export
- AI-assisted client summary generation and PDF export
- Authentication (SSO), RBAC, MFA, and session management
- Admin panel for user and rule management
- Notifications (in-app and email) for workflow events

1.2 Out of Scope

- Real-time market data integration
- Trade execution or OMS connectivity
- Client self-service portal or direct client login
- Native mobile application (iOS/Android)
- External CRM integration (Phase 2)
- Regulatory filing/report submission to external bodies

2. Assumptions & Constraints

The following assumptions have been identified. Items marked "Inferred" are architectural judgements made in the absence of explicit requirements and should be validated with the business.

ID	Source	Assumption / Constraint
A1	DOCUMENT	MVP will use mock/seeded data; live custodian data integration is deferred.
A2	DOCUMENT	Compliance rules implemented as a simplified, configurable rules engine.
A3	DOCUMENT	Platform is single-tenant for MVP; multi-tenancy is Phase 2.
A4	DOCUMENT	All users are internal employees; external client access is out of scope.
A5	DOCUMENT	Platform will be deployed in a cloud-hosted environment (AWS or Azure).
A6	INFERRED	All API endpoints require authentication and enforce RBAC.
A7	INFERRED	Audit logs are append-only and retained for 7 years.
A8	INFERRED	All data at rest is encrypted using AES-256; in transit via TLS 1.3.
A9	INFERRED	AI summary generation uses a third-party LLM API (e.g., Azure OpenAI).
A10	INFERRED	Object storage is used for proposal attachments (PDFs).

3. High-Level Design (HLD)

3.1 System Architecture Overview

The platform adopts a layered, service-oriented architecture with clear separation between presentation, application, business logic, and data tiers. The frontend is a React-based SPA, communicating via a secure API gateway to backend microservices. Authentication is handled via SSO (SAML 2.0/OIDC) with RBAC and MFA. The business logic layer includes services for proposal management, suitability validation, workflow orchestration, and notifications. Data is persisted in a relational database (PostgreSQL), with Redis for caching and object storage for attachments. All actions are logged immutably for compliance. The architecture emphasizes scalability, security, and auditability, supporting up to 500 concurrent users and 99.5% uptime. Key design decisions include use of a configurable rules engine for suitability, cloud-native deployment (Kubernetes), and integration with external services for identity, email, and AI summary generation. Quality attributes prioritized are security, compliance, performance, availability, and extensibility.

3.2 Architecture Principles

- Separation of Concerns
- Security by Design
- Least Privilege Access
- Auditability and Traceability
- Scalability and Elasticity
- Resilience and Fault Tolerance
- API-First Design
- Configurable Compliance
- Immutable Data Logging
- Cloud-Native Deployment

3.3 Major Components & Modules

The following table summarises the major components of the system:

Component	Tier	Description	Technologies
Web Application (React)	Presentation	Single-page application for advisors, compliance, and admin users.	React 18, TypeScript, Redux, Material UI
API Gateway	Application	Central entry point for all API traffic; enforces security and routing.	Kong, NGINX, OAuth2 Proxy
Auth Service	Business Logic	Handles SSO, session management, RBAC, and MFA.	Node.js, Passport.js, OIDC/SAML libraries

Component	Tier	Description	Technologies
Proposal Service	Business Logic	Manages proposal lifecycle, versioning, and state transitions.	Node.js, Express, TypeORM
Suitability Engine	Business Logic	Executes configurable compliance rules on proposals.	Node.js, Rules Engine, JSON Schema
Notification Service	Integration	Dispatches in-app and email notifications for workflow events.	Node.js, SendGrid SDK, SMTP
AI Summary Service	Integration	Generates client summaries using an external LLM API.	Node.js, Azure OpenAI SDK, REST
Audit Trail Service	Business Logic	Records all user/system actions immutably for compliance.	Node.js, PostgreSQL, Elasticsearch
Admin Service	Business Logic	Manages users, roles, SSO config, and compliance rules.	Node.js, Express, TypeORM
Database	Data	Stores all structured data: users, clients, portfolios, proposals, audit logs.	PostgreSQL 15
Cache	Data	Accelerates read-heavy queries and stores session data.	Redis 7
Object Storage	Data	Stores proposal attachments (PDFs) securely.	AWS S3, Azure Blob Storage
Identity Provider	Integration	External SSO provider for authentication.	Azure AD, Okta
Email Gateway	Integration	External service for transactional email delivery.	SendGrid, SMTP

Web Application (React)

Tier: Presentation

Single-page application for advisors, compliance, and admin users.

Responsibilities:

- Render dashboards, portfolio views, proposal editor, and admin screens
- Handle user input, validation, and navigation

API Gateway

Tier: Application

Central entry point for all API traffic; enforces security and routing.

Responsibilities:

- Route requests to backend services
- Enforce authentication, rate limiting, and logging

Auth Service

Tier: Business Logic

Handles SSO, session management, RBAC, and MFA.

Responsibilities:

- Validate JWTs and user sessions
- Manage user roles and permissions

Proposal Service

Tier: Business Logic

Manages proposal lifecycle, versioning, and state transitions.

Responsibilities:

- Create, edit, submit, and version proposals
- Enforce workflow and audit logging

Suitability Engine

Tier: Business Logic

Executes configurable compliance rules on proposals.

Responsibilities:

- Validate proposals against risk profile and rules
- Generate structured validation reports

Notification Service

Tier: Integration

Dispatches in-app and email notifications for workflow events.

Responsibilities:

- Send notifications on proposal state changes
- Escalate overdue reviews

AI Summary Service

Tier: Integration

Generates client summaries using an external LLM API.

Responsibilities:

- Format prompt and call LLM API
- Return editable summary to frontend

Audit Trail Service

Tier: Business Logic

Records all user/system actions immutably for compliance.

Responsibilities:

- Append audit log entries for all critical actions
- Support search and export

Admin Service

Tier: Business Logic

Manages users, roles, SSO config, and compliance rules.

Responsibilities:

- User provisioning and deactivation
- Rule configuration and delegation

Database

Tier: Data

Stores all structured data: users, clients, portfolios, proposals, audit logs.

Responsibilities:

- Persist transactional and reference data
- Enforce constraints and retention policies

Cache

Tier: Data

Accelerates read-heavy queries and stores session data.

Responsibilities:

- Cache portfolio and proposal data
- Store ephemeral session tokens

Object Storage

Tier: Data

Stores proposal attachments (PDFs) securely.

Responsibilities:

- Persist and serve file uploads
- Enforce encryption and retention

Identity Provider

Tier: Integration

External SSO provider for authentication.

Responsibilities:

- Authenticate users via SAML/OIDC
- Provide user attributes for RBAC

Email Gateway

Tier: Integration

External service for transactional email delivery.

Responsibilities:

- Send workflow notifications
- Support escalation and approval alerts

3.4 User & Data Flow

User actions in the web application trigger API calls routed through the API Gateway. The gateway authenticates requests via the Auth Service, which validates SSO tokens and enforces RBAC. Proposal-related requests are handled by the Proposal Service, which interacts with the Suitability Engine for validation and the Audit Trail Service for logging. Data is persisted in PostgreSQL, with Redis caching for performance and object storage for attachments. Notifications are dispatched via the Notification Service, integrating with the Email Gateway. AI summary requests are sent to the AI Summary Service, which calls an external LLM API and returns results to the frontend. All critical actions are logged immutably for compliance.

3.5 External Integrations

Integration	Type	Protocol	Direction	Description
Identity Provider (SSO)	OAuth SAML	HTTPS (OIDC/SAML 2.0)	Inbound	Authenticate users via firm's IdP for SSO and RBAC.
Email Notification Service	REST API SMTP	HTTPS SMTP	Outbound	Send workflow and escalation notifications.
AI/LLM Service	REST API	HTTPS	Outbound	Generate client summaries using external LLM.

Integration	Type	Protocol	Direction	Description
Object Storage	S3/Blob	HTTPS	Outbound	Store and retrieve proposal attachments securely.

3.6 Architecture Diagram

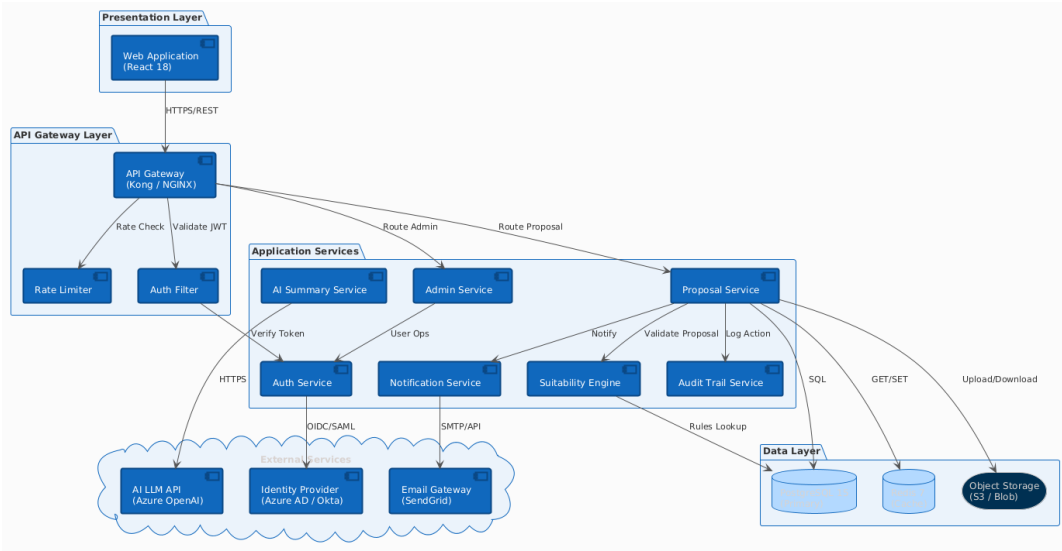


Figure: System Architecture Overview

3.7 Component Interaction Diagram

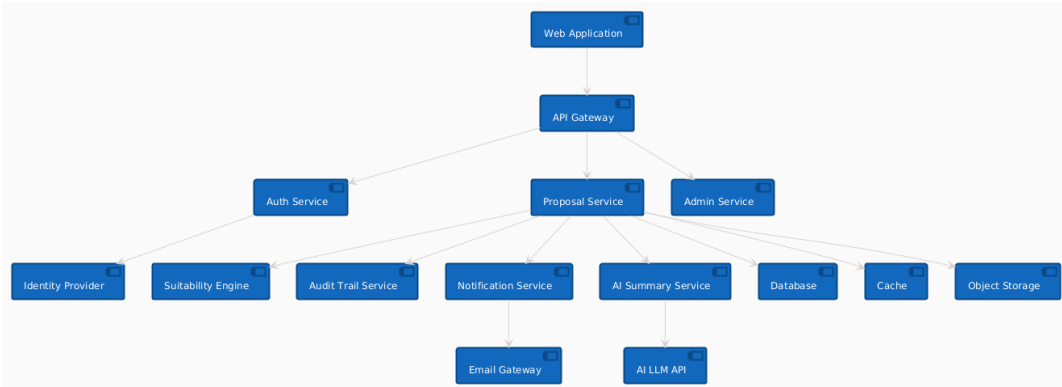


Figure: Component Interaction Diagram

3.8 Data Flow Diagram

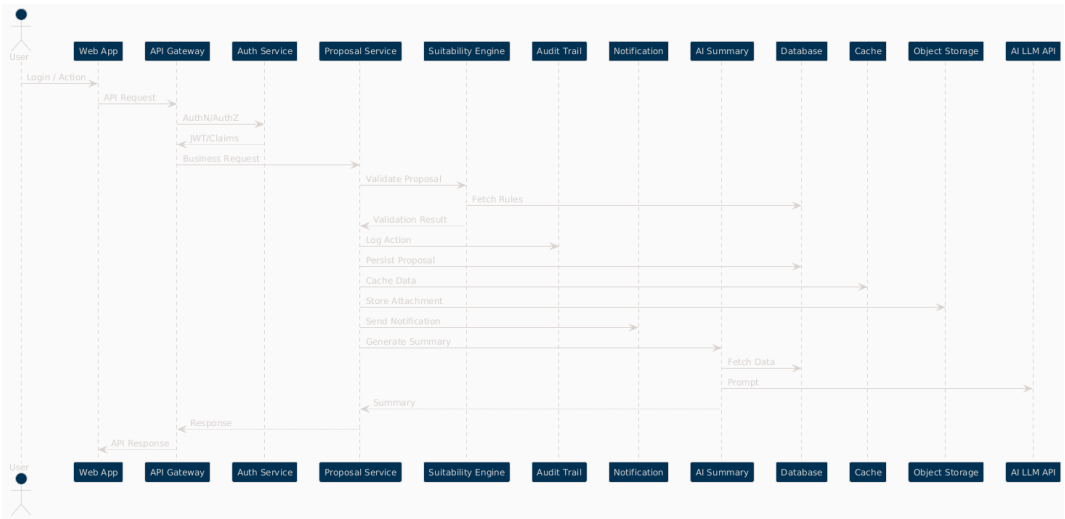


Figure: Data Flow Diagram

